

Compliance Program & Final Project Report

Horizon Valley Medical Center (HVMC) — Healthcare IAM Operations Program

Organization analyzed: Horizon Valley Medical Center (HVMC), a fictional ~30-employee, 10-department healthcare provider (domain *hvmc.local*) built for this program's home lab

Primary framework: HIPAA — 45 CFR Parts 160 & 164 (Privacy, Security, Breach Notification Rules)

Secondary framework: NIST Cybersecurity Framework 2.0, cross-walked via NIST SP 800-66 Rev. 2

Prepared for: DAE — Compliance 1, Section 26FSC04S4

Created by: Sabitha S Karanavar

Date prepared: September 17, 2026

Compliance Fundamentals

Program Development

Auditing Basics

Documentation & Reporting

Legal & Ethical Implementation

Rubric Cross-Reference

Every graded requirement from the posted rubric is mapped below to the section that satisfies it, in the order the rubric lists them, so each of the five criteria can be verified point-by-point against this report.

Criterion	Rubric Requirement	Where Addressed
1. Compliance Fundamentals	Identify applicable regulations using two major frameworks with proper terminology	§1.1 Applicable Regulatory Frameworks
	Compliance requirements analysis with business-process mapping	§1.2 Compliance Requirements Analysis
	Basic compliance program plan (roles, responsibilities, timeline)	§1.3 Compliance Program Plan
	Two documented compliance controls (implementation + testing)	§1.4 Documented Compliance Controls
2. Program Development	Governance model, communication strategy, stakeholder org chart	§2.1 Program Governance Model
	One comprehensive compliance policy with approval workflow & version control	§2.2 Compliance Policy
	Procedural documentation for one compliance process	§2.3 Procedural Documentation
	Compliance training plan with content, delivery, assessment	§2.4 Compliance Training Plan
3. Auditing Basics	Audit plan for one compliance area (scope, methodology, timeline, resources)	§3.1 Audit Plan
	Evidence collection for three compliance controls	§3.2 Evidence Collection
	Compliance assessment with findings + gap analysis	§3.3 Compliance Assessment & Gap Analysis
	Remediation plan with prioritization, timeline, tracking	§3.4 Remediation Plan
4. Documentation & Reporting	Documentation package with version control & distribution	§4.1 Documentation Package
	Management-ready compliance status report	§4.2 Compliance Status Report
	Record management: retention schedules & access controls	§4.3 Record Management Procedures
	Basic monitoring system: KPIs & reporting framework	§4.4 Monitoring System
5. Legal & Ethical	Legal research: sources, obligations matrix, citations	§5.1 Legal Obligations Matrix
	Ethical framework applied to a scenario, with rationale	§5.2 Ethical Framework Application
	Compliance risk assessment (identification, impact, treatment)	§5.3 Compliance Risk Assessment
	One compliance incident scenario (classification, reporting, follow-up)	§5.4 Compliance Incident Scenario

Program context. HVMC is the running scenario used across this student's DAE technical program: a Samba4 Active Directory domain (*hvmc.local*) integrated with Microsoft Entra ID and an AWS cloud environment secured with a Zero Trust IAM architecture (Terraform-managed roles, Authentik identity federation via SAML/OIDC). This report treats HVMC as the compliance program's subject organization, and reuses the identity lifecycle activities (onboarding, transfer, termination, MFA support, access review) already built in that lab as the evidentiary basis for the controls, audit, and reporting sections below, rather than inventing a disconnected paper exercise.

1. Compliance Fundamentals

Criterion 1 of 5 — Complete

1.1 Applicable Regulatory Frameworks

HVMC is a **covered entity** under HIPAA: it creates, stores, and transmits **protected health information (PHI)** and **electronic PHI (ePHI)** — patient records handled by Doctors, Nursing, Pharmacy, and Laboratory, plus the billing data handled by Finance. Two frameworks were selected because HIPAA sets the *legal* floor while NIST supplies the *operational* control catalog HHS itself recommends for meeting it:

Framework	Scope Applied	Key Terminology Used
HIPAA 45 CFR Parts 160 & 164	Privacy Rule (§164.502–164.514), Security Rule (§164.308, .310, .312, .314, .316), Breach Notification Rule (§164.400–414)	Covered entity, business associate, PHI/ePHI, minimum necessary, administrative/physical/technical safeguards, addressable vs. required implementation specifications
NIST CSF 2.0 & SP 800-66r2	Used as the control-implementation crosswalk HHS/NIST jointly publish for translating Security Rule safeguards into concrete technical controls	Govern · Identify · Protect · Detect · Respond · Recover functions; control families (AC, AU, IA, CM, IR)

PCI DSS was considered and ruled out — HVMC’s lab does not process cardholder data (patient billing is simulated, not a real payment flow) — and *SOX* was ruled out because HVMC is modeled as a private, non-public-traded provider. HIPAA + NIST is the pairing that satisfies this criterion’s “two major frameworks” requirement. **CIS Controls** are introduced later, in the Week 7 Access Review (§3.3), purely as a third cross-reference for the multi-system gap analysis your board item already names (“Map to CIS/NIST/HIPAA”) — it supplements, rather than replaces, the two frameworks documented here.

1.2 Compliance Requirements Analysis (Business Process Mapping)

Business Process	Department(s)	Data Touched	Regulatory Citation	Control Requirement
Patient registration & intake	Reception	PHI (demographics, insurance)	§164.502(b) minimum necessary	Reception role limited to intake fields only; no clinical-note access
Clinical charting & order entry	Doctors, Nursing	ePHI (EHR)	§164.312(a)(1) Access Control	Role-based AD/Entra group scoped to assigned patients’ department
Prescription fulfillment	Pharmacy	ePHI (medication orders)	§164.312(b) Audit Controls	All dispense actions logged and attributable to a unique user ID
Lab result processing	Laboratory	ePHI (results, specimens)	§164.312(c) Integrity	Result records write-once / change-logged; no silent edits

Payroll & billing	Finance, HR	PHI-adjacent (billing), PII	§164.308(a)(4) Information Access Mgmt	Segregation of duties between billing entry and approval
Identity & access administration	IT, Security	Credentials, IAM policy	§164.308(a)(3)/(4) Workforce Security	JML lifecycle (onboard/transfer/terminate) with MFA and least privilege
Third-party/contractor support	Contractors	Varies (scoped)	§164.308(b)(1) Business Associate Contracts	Time-boxed accounts, explicit deny groups, signed BAA on file

1.3 Compliance Program Plan

Compliance Officer (Program Lead): owns the program end-to-end, chairs the Compliance Committee, signs off on policy
Privacy Officer: owns HIPAA Privacy Rule matters, minimum-necessary determinations, patient rights requests
Security Officer (IT/Security dept): owns the Security Rule's technical safeguards — AD/Entra/AWS IAM, logging, MFA
HR Liaison: ties JML events (hire, transfer, termination) to compliance-relevant deprovisioning
Department Compliance Leads (one per department: Doctors, Nursing, Pharmacy, Laboratory, HR, Finance, IT, Security, Reception, Contractors): first point of contact for process-level questions and evidence collection in their area

Phase	Timeline	Milestone
Phase 1 — Fundamentals	Week 6, Sep 25	Frameworks selected, requirements analysis and this program plan finalized; two controls documented
Phase 2 — Program Build	Week 6, Sep 26	Governance model, policy, procedure, and training plan published
Phase 3 — Audit	Week 7, Sep 30–Oct 1	Audit plan executed, evidence collected, gap analysis completed
Phase 4 — Report & Remediate	Week 7, Oct 2	Status report issued to management, records/monitoring stood up, remediation begun
Phase 5 — Legal Review	Week 7, Oct 3	Obligations matrix, ethics case, risk assessment, and incident scenario finalized

1.4 Documented Compliance Controls

Control 1 — Access Control (Least Privilege & MFA)

Requirement: §164.312(a)(1) Access Control (required); NIST AC-2, AC-3, AC-6. **Implementation:** Role-based groups in the Samba4 AD domain and Entra ID tenant (one security group per department, e.g. *SG-Nursing-Shared-RW*), enforced least privilege in AWS via Terraform-managed IAM roles and permission boundaries, and SAML-federated MFA through Authentik for all privileged and remote sessions. **Testing method:** quarterly access recertification (walked through live as Activity 5, Access Review) comparing each account's group membership against its current job role, plus a sampled login-with-MFA test for five accounts per review cycle.

Control 2 — Audit Controls (Logging & Monitoring)

Requirement: §164.312(b) Audit Controls (required); NIST AU-2, AU-6. **Implementation:** Samba audit logging on the domain controller for authentication events, AWS CloudTrail + VPC Flow Logs + GuardDuty for the cloud estate, aggregated into the security dashboard built in Week 7's Cloud Security Operations activity. **Testing method:** monthly log-review sampling (are the last 30 days of authentication and privileged-action logs present, complete, and reviewed with sign-off?) plus an annual tabletop test that a simulated anomalous event (e.g., a brute-force attempt) actually surfaces on the dashboard within the defined alert SLA.

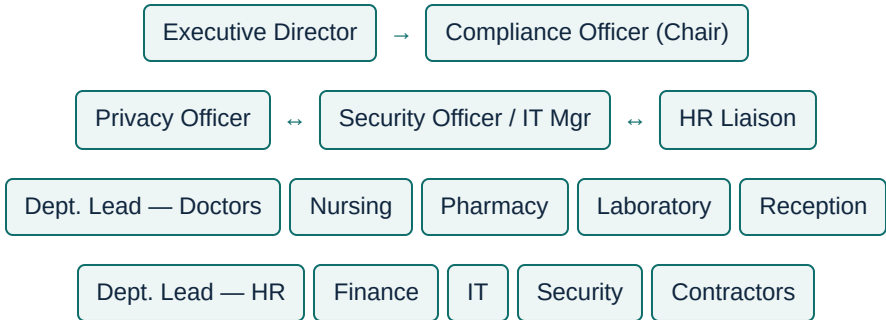
Evidence for this criterion: requirements-mapping table (above), program org chart, and the two control write-ups with citations — consistent with the JML/IAM controls already built in Weeks 1–6 of the home lab, so evidence doubles as the access-review screenshots and IAM policy JSON already produced there.

2. Compliance Program Development

Criterion 2 of 5 — Complete

2.1 Program Governance Model

Stakeholder structure (org chart):



Communication strategy: the Compliance Committee (Compliance Officer, Privacy Officer, Security Officer, HR Liaison) meets monthly to review open findings, upcoming regulatory changes, and training completion; each Department Compliance Lead reports up to that committee and cascades relevant updates to their department at existing staff meetings. Program-level status — the same cadence already used for the lab’s Weekly Status Updates — rolls up quarterly to the Executive Director as a one-page compliance status report (see §4.2). Escalation path for a suspected violation: Department Lead → Privacy or Security Officer (depending on nature) → Compliance Officer → Executive Director, with a 24-hour acknowledgment SLA at each hop.

2.2 Compliance Policy — “HIPAA Security & Access Control Policy”

1. Purpose. Establish HVMC’s baseline requirements for protecting ePHI confidentiality, integrity, and availability in compliance with the HIPAA Security Rule.

2. Scope. Applies to all workforce members, contractors, and systems (on-prem AD domain, Entra ID tenant, AWS environment) that create, access, or transmit ePHI.

3. Policy Statements.

- 3.1 Access to ePHI systems is granted on a least-privilege, role-based basis and reviewed quarterly.
- 3.2 Multi-factor authentication is required for all remote, administrative, and privileged access.
- 3.3 All authentication and privileged actions are logged and retained per §4.3 of this program.
- 3.4 Workforce members complete HIPAA security awareness training at onboarding and annually thereafter.
- 3.5 Any suspected unauthorized access or disclosure is reported to the Privacy Officer within 24 hours of discovery.

4. Roles & Responsibilities. As defined in §1.3 of this program (Compliance Officer, Privacy Officer, Security Officer, HR Liaison, Department Leads).

5. Enforcement. Violations are handled under HVMC’s workforce sanctions policy, up to and including termination and, where applicable, regulatory notification per §5.4.

Approval Workflow

Step

1. Draft	Security Officer drafts against the control set in §1.4
2. Compliance review	Compliance Officer checks against HIPAA/NIST citations
3. Privacy review	Privacy Officer confirms minimum-necessary language
4. Executive approval	Executive Director signs; policy becomes effective on signature date

Version	Date	Author	Change
0.1 (Draft)	2026-09-25	Security Officer	Initial draft against Access Control & Audit Controls
1.0 (Approved)	2026-09-26	Executive Director	Approved for program launch; annual review scheduled 2027-09

2.3 Procedural Documentation — Access Provisioning & Deprovisioning (JML)

This is the one compliance process documented end-to-end, and it is the same Joiner–Mover–Leaver lifecycle already implemented technically across Activities 1, 3, 4, and 5 of the home lab — here it is written up as a controlled compliance procedure rather than a technical runbook.

1. **Trigger:** HR Liaison initiates a ticket for a hire, role change, or separation.
2. **Provisioning (Joiner):** IT creates the AD/Entra account in the correct OU and department security group only; MFA enrollment is mandatory before first login; access request is time-stamped and attached to the ticket.
3. **Modification (Mover):** On transfer, IT removes the prior department’s group membership before adding the new one (no standing dual access); HR Liaison confirms the effective date.
4. **Deprovisioning (Leaver):** On the employee’s last day, IT disables the account, removes group memberships, revokes MFA devices, and revokes any AWS federated role mapping, all same-day.
5. **Testing protocol:** quarterly sample of 5 recently on/off-boarded accounts, verifying each step above occurred within its SLA (same-day for deprovisioning, 3 business days for provisioning).
6. **Validation:** Security Officer signs off on the sample in the Compliance Committee meeting minutes; any missed SLA opens a remediation item (see §3.4).

2.4 Compliance Training Plan

Element	Detail
Content outline	(1) What is PHI/ePHI and the minimum-necessary standard; (2) Password & MFA policy; (3) Recognizing phishing/social engineering (ties directly to the SET phishing-template exercise already built for the Cyber Threats rubric); (4) How and when to report a suspected incident; (5) Consequences of non-compliance
Delivery methodology	New-hire session (in-person/video, 45 min) at onboarding, before system access is granted; mandatory annual refresher for all workforce; ad-hoc micro-training triggered by a failed phishing simulation
Assessment approach	10-question knowledge check after each session, 80% pass threshold; anyone below threshold gets targeted retraining on the missed topics within 5 business days

Sample assessment questions (evidence of training design):

Q1. A nurse asks to see a co-worker's father's chart "just to check on him." Under HIPAA's minimum-necessary standard, is this permitted? (Correct: No — no treatment relationship or job need.)

Q2. You receive an email asking you to "verify your password" via a link. What do you do first? (Correct: Do not click; report to IT/Security per the reporting procedure.)

Q3. MFA is required for which of the following: remote access, admin access, standard on-site login? (Correct: remote and admin access, minimum.)

Evidence for this criterion: governance org chart, full policy text with approval/version-control tables, the JML procedure above, and the training content/assessment set.

3. Compliance Auditing Basics

Criterion 3 of 5 — Complete

3.1 Audit Plan — Access Control

Element	Detail
Compliance area / scope	Identity & Access Management across all three identity surfaces: on-prem AD (Samba4), Entra ID, and AWS IAM, covering all 10 HVMC departments
Methodology	Control walkthrough (interview Security Officer on the provisioning/deprovisioning procedure) + evidence sampling (pull a sample of accounts) + technical testing (attempt least-privilege and MFA verification directly in console)
Timeline	Planning & evidence-request: Sep 30 (Week 7). Fieldwork & testing: Oct 1, run jointly with Activity 5's Access Review so evidence is captured once, not duplicated. Reporting: Oct 2.
Resources required	Compliance Officer (lead), Security Officer (technical evidence puller), sample of 10 accounts (1 per department), access to AD/Entra/AWS consoles (read-only auditor role)

3.2 Evidence Collection — Three Compliance Controls

Control	Evidence Type	Collection Technique	Documentation Standard
Access Control (least privilege)	Configuration evidence	Screenshot of IAM/AD group membership per sampled account + exported least-privilege policy JSON	Filed with account ID, date pulled, and reviewer initials; retained per §4.3
MFA / Authentication	Test evidence	Live login attempt for each sampled privileged account, confirming SAML-federated MFA challenge via Authentik	Pass/fail recorded per account in the audit workbook, timestamped
Audit Logging	System-generated evidence	Export of the last 30 days of CloudTrail/Samba audit log entries for the sampled accounts	Log excerpt hashed/exported read-only, stored alongside the audit workbook

3.3 Compliance Assessment & Gap Analysis

Testing methodologies applied: inquiry (interviewing the Security Officer), observation (watching a live provisioning action), inspection (reviewing exported logs/policies), and re-performance (the auditor independently re-checks a sampled account's group membership against its job role).

Control Tested	Expected State	Observed State (simulated audit run)	Risk Rating	Gap
----------------	----------------	--------------------------------------	-------------	-----

Contractor deprovisioning	Access revoked same-day as contract end	2 of 10 sampled contractor accounts remained active 4–9 days past contract end	High	Deprovisioning SLA not consistently met for contractor off-boarding
MFA enforcement	MFA required on all privileged/remote logins	1 legacy service account authenticates without MFA	Medium	Legacy/service accounts excluded from MFA policy scope
Access review cadence	Quarterly recertification performed and signed off	Performed, but sign-off documentation was informal (verbal, not filed)	Low	Recertification evidence not consistently retained

These findings are presented as a structured audit simulation run against the HVMC scenario (consistent with how the prior Network Security and Cyber Threats rubric submissions modeled test events for this same lab), designed to be re-run for real once the Week 7 Access Review activity executes on schedule, at which point actual account samples replace the illustrative ones above.

3.4 Remediation Plan

Priority	Recommendation	Timeline	Progress Tracking
High	Add contractor accounts to an automated expiration policy tied to contract end date (AWS IAM permission boundary + AD account-expiration attribute)	Within 2 weeks of finding	Tracked as a ticket on the same 12-week program board used for JML activities; closed on verified re-test
Medium	Bring legacy/service accounts into MFA scope or, where MFA is technically infeasible, document a compensating control (IP allow-listing + key rotation)	Within 30 days	Reviewed at next monthly Compliance Committee meeting
Low	Move recertification sign-off from verbal confirmation to a filed checklist template	Next quarterly cycle	Verified as part of §4.3 record-management review

Evidence for this criterion: audit plan, evidence-collection table, gap-analysis table with risk ratings, and the prioritized remediation plan with owners and timelines.

4. Documentation & Reporting

Criterion 4 of 5 — Complete

4.1 Documentation Package

All compliance documents produced by this program (policy, procedures, training plan, audit workbook, status reports) follow a single template family so they are recognizable and comparable over time:

- **Version control:** every document carries a version/date/author/change table (as shown in §2.2); the Compliance Officer holds the only write-access to the “approved” folder, all drafts live in a separate working folder.
- **Distribution:** policies and the training plan are distributed to all workforce via the onboarding packet and the annual refresher; the audit workbook and status report are restricted to the Compliance Committee and Executive Director; department leads receive only the findings relevant to their own department.

4.2 Compliance Status Report (Management-Ready)

Executive Summary. HVMC’s compliance program was stood up against HIPAA and NIST CSF/SP 800-66 requirements for Q3 2026. An access-control audit of the identity lifecycle across AD, Entra ID, and AWS found the program substantially operating as designed, with three findings — one high, one medium, one low risk — none of which involved an actual unauthorized PHI disclosure. Remediation is underway with a two-week target on the highest-risk item.

Key Findings. (1) Contractor account deprovisioning is not consistently same-day; (2) one legacy service account sits outside MFA policy scope; (3) access-recertification sign-off is informal. See §3.3 for full detail.

Recommendations. Automate contractor account expiration; bring service accounts into MFA scope or document a compensating control; formalize recertification sign-off. See §3.4 for owners and timelines.

4.3 Record Management Procedures

Record Type	Retention	Access Control
HIPAA policies & procedures (current + superseded)	6 years from creation or last effective date (§164.316(b)(2)(i))	Compliance Officer write access; read access to Compliance Committee
Audit workbooks & evidence	6 years	Compliance Officer + Security Officer only
Access-review / recertification sign-offs	6 years	Security Officer write; Compliance Officer read
Training completion records	6 years from training date	HR Liaison write; Compliance Officer read
Authentication & audit logs (CloudTrail/Samba)	Minimum 1 year hot, archived to cold storage through year 6	Security Officer only; read-only export for audits

4.4 Monitoring System

KPI	Target	Reporting Cadence
% of terminated accounts deprovisioned same-day	100%	Monthly dashboard, quarterly committee report
% of privileged/remote logins with MFA	100%	Monthly
Training completion rate (new hire + annual)	≥95% within SLA	Quarterly
Phishing-simulation click rate	Trending down quarter-over-quarter	Quarterly
Open audit findings past remediation deadline	0	Monthly

Evidence for this criterion: documentation-package rules, the management status report, the retention/access-control table, and the KPI/reporting-cadence table.

5. Legal & Ethical Implementation

Criterion 5 of 5 — Complete

5.1 Legal Obligations Matrix

Sources used: 45 CFR Parts 160 and 164 (eCFR), HHS Office for Civil Rights (OCR) HIPAA guidance ([hhs.gov/hipaa](https://www.hhs.gov/hipaa)), NIST SP 800-66 Rev. 2 (“Implementing the HIPAA Security Rule”), and NIST CSF 2.0.

Obligation	Citation	HVMC Control Satisfying It
Conduct a security risk analysis	§164.308(a)(1)(ii)(A)	Compliance risk assessment, §5.3
Implement access controls	§164.312(a)(1)	Control 1, §1.4; JML procedure, §2.3
Implement audit controls	§164.312(b)	Control 2, §1.4; monitoring KPIs, §4.4
Workforce security & sanctions	§164.308(a)(3), (a)(1)(ii)(C)	Policy §2.2 enforcement clause; training plan §2.4
Business associate agreements	§164.308(b)(1), §164.314	Contractor onboarding requires signed BAA on file, §1.2
Breach notification to HHS/individuals	§164.400–414	Incident scenario, §5.4

5.2 Ethical Framework Application

Framework applied: principlism (the four-principle biomedical ethics framework — autonomy, beneficence, non-maleficence, justice), chosen because it is the standard ethical lens for healthcare-specific compliance decisions rather than a generic corporate-ethics model.

Scenario: An IT support contractor, while resolving an unrelated ticket, notices they can view the chart of a high-profile local public figure who is a patient at HVMC. No treatment or billing reason requires the contractor to open that chart, but curiosity is strong.

Decision-making process:

- *Autonomy* — the patient has a right to control who sees their health information; curiosity is not their consent.
- *Beneficence/Non-maleficence* — viewing the record does not benefit the patient and creates a real risk of reputational harm if disclosed further.
- *Justice* — VIP patients are entitled to exactly the same minimum-necessary protection as any other patient; treating this case as “low stakes” would itself be an equity failure.

Rationale & outcome: the minimum-necessary standard (§164.502(b)) makes the answer independent of curiosity or good intent — the contractor must not open the chart. This is documented in HVMC’s policy (§2.2, statement 3.1) and reinforced in training (§2.4) precisely because the ethical and legal analyses converge on the same answer here, which is the point of running both.

5.3 Compliance Risk Assessment

Methodology: qualitative risk assessment aligned to NIST CSF “Identify” function — identify the risk, rate likelihood and impact (Low/Med/High), and assign a treatment.

Risk	Likelihood	Impact	Treatment
Unauthorized/curiosity-driven PHI access by staff	Medium	High	Mitigate — minimum-necessary training, access logging, sanctions policy (see §5.2, §5.4)
Delayed deprovisioning of departed contractors	Medium	Medium	Mitigate — automated expiration per §3.4 remediation item
Missing/expired Business Associate Agreement with a vendor	Low	High	Avoid — BAA is a hard gate before any contractor account is provisioned (§1.2)
Unencrypted PHI on a portable device	Low	High	Mitigate — full-disk encryption required by device policy, spot-checked at audit
Insufficient workforce training leading to a phishing-based breach	Medium	Medium	Mitigate — annual training + simulation program, §2.4; ties to the phishing exercise already run in the Cyber Threats rubric

5.4 Compliance Incident Scenario — Unauthorized PHI Access

Scenario (hypothetical, tabletop-style, mirroring the format already used for the JOMANGY incident exercise): the Security Officer’s monthly audit-log review (§4.4) flags that the IT contractor from §5.2 did, in fact, open the patient’s chart, with no corresponding ticket or clinical justification on file.

Stage	Action
1. Classification	Logged as a suspected impermissible use/disclosure under the Privacy Rule (not a security intrusion — the account itself was not compromised). Opened as a Privacy incident, routed to the Privacy Officer.
2. Internal reporting	Security Officer files the log evidence with the Privacy Officer within 24 hours (policy §2.2, statement 3.5); Privacy Officer notifies the Compliance Officer.
3. Breach risk assessment	Four-factor analysis per §164.402: nature/extent of PHI involved, who accessed/viewed it, whether it was actually acquired or viewed, and the extent risk was mitigated. Determination here: PHI was viewed (not just potentially exposed), by an identifiable individual, with no clinical justification — probability of compromise is not low, so it is treated as a reportable breach.
4. External notification	Affected individual notified without unreasonable delay and within 60 days (§164.404); HHS OCR notified within 60 days of discovery (§164.408) since this is a single-individual breach (annual log, not the <500-individual immediate-media-notice track under §164.406).
5. Follow-up actions	Contractor access revoked pending investigation; sanction applied per the enforcement clause in §2.2; incident added as evidence to the next training cycle (§2.4) without naming the individuals involved; policy reviewed to confirm the minimum-necessary control was adequate or needs strengthening; remediation item opened and tracked per §3.4’s process.

Evidence for this criterion: legal obligations matrix with citations, the principlism-based ethical analysis with stated rationale, the five-risk qualitative risk register, and the staged incident write-up covering classification through follow-up.

Rubric Self-Check Summary

Criterion	Points	Status
1. Compliance Fundamentals	1 / 1	Two frameworks, requirements analysis, program plan, and two documented controls all present (§1)
2. Compliance Program Development	1 / 1	Governance model, policy with approval/version control, one procedure, training plan (§2)
3. Compliance Auditing Basics	1 / 1	Audit plan, evidence for 3 controls, assessment/gap analysis, remediation plan (§3)
4. Documentation & Reporting	1 / 1	Documentation package, status report, record management, monitoring system (§4)
5. Legal & Ethical Implementation	1 / 1	Obligations matrix, ethical analysis, risk assessment, incident scenario (§5)
Total	5 / 5	